



**IN RE: UNIVERSITY OF PERPETUAL
HELP DALTA MEDICAL CENTER, INC.**

NPC BN 22-208

X-----X

ORDER

Before the Commission is the Compliance of the University of Perpetual Help Delta Medical Center, Inc. (UPHDMC) dated 11 December 2023 in accordance with the Minute Resolution dated 24 November 2023.

On 26 November 2022, UPHDMC's servers were infected by a ransomware known as Lockbit 3.0, causing unavailability of databases and files, which affected the following systems:

- a) Hospital Information System (Bizbox Modules Include: Materials Management System, Financial Management System, Philhealth Information System)
 - Identifiable data: Patient Name, Doctor Name, Date of Birth, Address, Mobile Number, Religion, Senior/PWD ID Number, Diagnosis, HMO Name, Principal/Vendor Name, TIN Number, Philhealth ID Number, and PRC ID Number
- b) Diagnostic Systems (Laboratory Information System (LIS), Molecular Information System (MIS))
 - Identifiable data: Patient Name, Doctor Name, Date of Birth, Test Result, and Mobile Number
- c) Public/Shared Folders
 - Identifiable data: Patient Name, Doctor Name, Date of Birth, Address, Mobile Number, Senior/PWD ID Number, Diagnosis, and HMO Name
- d) Timekeeping/Payroll System
 - Identifiable data: Employee Name, Date of Birth, Address, SSS Number, TIN Number, Philhealth ID Number, and PRC ID Number

- e) IT Ticketing System
 - Identifiable data: Employee Name
- f) Internal Email System
 - Identifiable data: Employee Name¹

In addition, the databases and files also contain the supplier's name, address, telephone, and Tax Identification Number (TIN).²

On the same day, UPHDMC's Information Technology (IT) Team employed measures to avoid the spread of the ransomware such as turning off the Internet Service Provider modems and removing all Local Area Network cables of all servers.³

UPHDMC thereafter identified the following vulnerabilities: outdated firewall, outdated endpoint protection (anti-virus), lack of secure remote connection, and use of external email sources.⁴

In order to prevent a recurrence of the incident, UPHDMC's action plans consist of procurement of a new firewall, email server, and its corresponding licenses, new subscription of endpoint protection, review and update of its policy for stricter provisioning of internet/Wi-Fi access, and improvement of response time and response type.⁵

On 30 November 2022, UPHDMC submitted its Personal Data Breach Notification Form (PDBNF) through the National Privacy Commission's (NPC) Data Breach Notification Management System (DBNMS), requesting for postponement of notification to the affected data subjects, on the basis that the systems affected involve countless data subjects and informing them all shall incur gargantuan costs.⁶

¹ *In re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Preliminary Data Breach Notification Form, Data Breach Notification Management System (DBNMS), 1.c Number of DS/Records.

² *Id.*, 2.a SPI, and 2.b Other info that may enable identity fraud.

³ *Id.*, 1.b Chronology.

⁴ *Id.*, 3.e Measures to prevent recurrence of incidence.

⁵ *In re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Preliminary Data Breach Notification Form, Data Breach Notification Management System (DBNMS), 3.e Measures to prevent recurrence of incidence.

⁶ *Id.*

Thus, UPHDMC prayed that the required notification be limited to those having transactions for the last six months from the date of the incident and that notification be done on a piecemeal basis within a reasonable period upon retrieval of any information that could help them communicate with the affected data subjects.⁷

On 24 November 2023, the Commission issued a Minute Resolution with the following dispositive portion:

Pursuant to Section 17 (D) of NPC Circular No. 16-03 (Personal Data Breach Management), the Commission may require additional information, if necessary, for the proper resolution of the request for postponement to notify the affected data subjects.

WHEREFORE, premises considered, the Commission hereby **ORDERS** University of Perpetual Help Dalta Medical Center, Inc. to **SUBMIT** within five (5) days upon receipt of this Minute Resolution proof to substantiate the requests for postponement to notify the affected data subjects.

Should the University of Perpetual Help Dalta Medical Center, Inc. fail to provide the foregoing, this matter shall be submitted for resolution based on the records before the Commission.

SO ORDERED.⁸

On 11 December 2023, UPHDMC submitted its Compliance, clarifying that "we actually requested for limiting notifications to active six months and sending in piecemeal and not postponement."⁹

Moreover, UPHDMC stated that it already sent a total of fifteen thousand one hundred and fifteen (15,115) notification letters to the affected data subjects:

Total number of notifications sent to patients: 13,806 out of 277,806

Total number of notifications sent to doctors: 590 out of 4,885

⁷ *Id.*

⁸ *In Re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Minute Resolution dated 24 November 2023, at p. 1.

⁹ Compliance dated 11 December 2023 of University of Perpetual Help Data Medical Center, Inc, at p. 1.

Total number of notifications sent to employees: 719 out of 1,097¹⁰

UPHDMC is also allegedly working together with their IT Department to finish sending the notification to the affected data subjects by the end of March 2024.¹¹

Following the abovementioned Compliance where UPHDMC posited that it started notifying the affected data subjects and declared that its request is not actually for postponement, such actions have rendered said request moot.

However, the Commission denies UPHDMC's requests to limit notification to those having transactions for the last six months and to notify the affected data subjects in a piecemeal manner.

Accordingly, the Commission finds that UPHDMC must notify the affected data subjects and submit proof of notification and its full breach report.

Section 11, NPC Circular No. 16-03 (Personal Data Breach Management) provides when notification shall be required, to wit:

SECTION 11. *When notification is required.*

Notification shall be required upon knowledge of or when there is reasonable belief by the personal information controller or personal information processor that a personal data breach requiring notification has occurred, under the following conditions:

A. The personal data involves sensitive personal information or any other information that may be used to enable identity fraud. For this purpose, "other information" shall include, but not be limited to: data about the financial or economic situation of the data subject; usernames, passwords and other login data; biometric data; copies of identification documents, licenses or unique identifiers like Philhealth, SSS, GSIS, TIN number; or other similar information, which may be made the basis of decisions

¹⁰ *Id.*, at p. 1.

¹¹ *Id.*, at p. 1.

concerning the data subject, including the grant of rights or benefits.

B. There is reason to believe that the information may have been acquired by an unauthorized person; and

C. The personal information controller or the Commission believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject.¹²

In this case, all the elements of mandatory breach notification are present. As to the first element, the incident that affected UPHDMC's systems contains sensitive personal information and other information that may be used to enable identity fraud.¹³

Section 3 (l) of Republic Act 10173 or the Data Privacy Act of 2012 (DPA) defines sensitive personal information as personal information:

- (1) About an individual's race, ethnic origin, marital status, age, color, and religious, philosophical or political affiliations;
- (2) About an individual's health, education, genetic or sexual life of a person, or to any proceeding for any offense committed or alleged to have been committed by such person, the disposal of such proceedings, or the sentence of any court in such proceedings;
- (3) Issued by government agencies peculiar to an individual which includes, but not limited to, social security numbers, previous or current health records, licenses or its denials, suspension or revocation, and tax returns; and
- (4) Specifically established by an executive order or an act of Congress to be kept classified.¹⁴

From the above definition, the sensitive personal information here are the following: Dates of Birth, Religions, Test Results, Diagnoses,

¹² National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 11 (15 December 2016) (NPC Circular 16-03).

¹³ NPC Circular 16-03, rule V, § 11.

¹⁴ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter I, § 3 (l) (2012).

Senior/PWD ID Numbers, TINs, Philhealth ID Numbers, SSS numbers and PRC ID Numbers.¹⁵

On the other hand, the names, addresses, and mobile numbers, when taken together, may, under the circumstances, be used to enable identity fraud, if applied in a manner that could expose the affected data subjects to harassment, discrimination, or other risks of real and serious harm.¹⁶

With regard to the second element, there is reason to believe that the information may have been acquired by an unauthorized person.¹⁷ Based on UPHDMC's own assessment in its PDBNF, it confirmed that "our servers are infected by a ransomware known as Lockbit 3.0 causing unavailability of databases and files and there is a possibility of databases and files theft."¹⁸

The third element is also apparent because UPHDMC believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject, in line with its admission that "if instigator of the ransomware was able to get files, information may be leaked."¹⁹

Several factors may be considered as to whether a real risk of serious harm is likely to arise, such as: "the nature of the information involved in the breach, amount of information of a data subject, period of time lapsed from the breach, purpose of the unauthorized acquisition, security measures implemented on the information, and extent of potential misuse and exposure of information involved in the breach, if any."²⁰

¹⁵ *In re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Preliminary Data Breach Notification Form, Data Breach Notification Management System (DBNMS), 2.a SPI, and 2.b Other info that may enable identity fraud.

¹⁶ NPC BN 18-141 (*unreported*), Resolution dated 30 June 2023, at p. 5.

¹⁷ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 11 (15 December 2016) (NPC Circular 16-03).

¹⁸ *In re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Preliminary Data Breach Notification Form, Data Breach Notification Management System (DBNMS), Brief Summary.

¹⁹ *Id.*, 1.e Likely consequences.

²⁰ NPC BN 17-028 & NPC BN 18-180 (*unreported*), Resolution dated 11 May 2023, at p. 8.

Aside from the fact that the incident involves sensitive personal information and other information that may be used to enable identity fraud, the huge number of affected data subjects also contributes to the gravity of the situation that could increase the risk of serious harm arising from the personal data breach.

From UPHDMC's Compliance, it can be gleaned that the affected data subjects total two hundred eighty-three thousand and seven hundred eighty-eight (283,788):

Total number of notifications sent to patients: 13,806 out of 277,806

Total number of notifications sent to doctors: 590 out of 4,885

Total number of notifications sent to employees: 719 out of 1,097²¹

On this note, Section 13 of NPC Circular 16-03 provides for additional factors that a personal information controller (PIC) shall consider if there is uncertainty as to the need to notify, such as when "the personal data reasonably believed to have been compromised involves at least one hundred (100) individuals."²²

Notwithstanding UPHDMC's claim in its Compliance that it partially notified the affected data subjects, without any substantiation, these bare allegations do not conform with the purpose of the notification requirement, which is "to protect themselves against the possible effects of the data breach."²³

Hence, the large number of affected data subjects, in addition to the attendance of the three elements of mandatory breach notification, mandates that UPHDMC must individually notify all affected data subjects, in line with NPC Circular 16-03.

Lastly, UPHDMC's requests to limit notification to those having transactions for the last six months from the date of the incident and

²¹ Compliance dated 11 December 2023 of University of Perpetual Help Data Medical Center, Inc, at p. 1.

²² National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 13 (15 December 2016) (NPC Circular 16-03).

²³ NPC Circular 16-03, rule V, § 18 (A).

to notify the affected data subjects in a piecemeal manner cannot be sustained.

As a rule, “notification of affected data subjects shall be done individually, using secure means of communication, whether written or electronic.”²⁴ There is nothing in the DPA or the other issuances of the NPC, that allows PICs to exercise the discretion to select the data subjects it wants to notify or to identify the order of notification by arranging them in batches, depending “upon retrieval of any information that could help them communicate with the affected data subjects.”²⁵

More so, that the affected data subjects are numerous and notifying them all will be too costly for UPHDMC are not sufficient justifications to support its requests. To emphasize, confining the data subjects to be notified based on their transaction date alone or prioritizing those whose information would first be obtained, will place the affected data subjects in unequal footing in relation to giving them the opportunity to “take the necessary precautions or other measures to protect themselves against the possible effects of the breach.”²⁶

It bears stressing that “the personal information controller shall establish means through which the data subjects can exercise their rights and obtain more detailed information relating to the breach.”²⁷ Contrary to its requests, UPHDMC, as the PIC, should ensure that it shall abide by this duty, consistent with the avowed purpose of the notification requirement under NPC Circular 16-03.²⁸

WHEREFORE, premises considered, the Commission resolves to:

- 1) **DENY** University of Perpetual Help Dalta Medical Center, Inc.’s requests to limit notification to those having transactions for the last six months from the date of the

²⁴ NPC Circular 16-03, rule V, § 18 (D).

²⁵ *In re: University of Perpetual Help Data Medical Center, Inc.*, NPC BN 22-208, Preliminary Data Breach Notification Form, Data Breach Notification Management System (DBNMS).

²⁶ National Privacy Commission, Personal Data Breach Management, NPC Circular 2016-03, rule V, § 18 (A) (15 December 2016) (NPC Circular 16-03).

²⁷ NPC Circular 16-03, rule V, § 18 (D).

²⁸ NPC Circular 16-03, rule V, § 18 (A).

incident and to notify the affected data subjects in a piecemeal manner;

- 2) **ORDER** University of Perpetual Help Delta Medical Center, Inc. to **notify all affected data subjects** and **submit proof of notification and its full breach report** directly to the Compliance and Monitoring Division (CMD) within fifteen (15) days from receipt of this Order; and
- 3) **DIRECT** the CMD to issue the appropriate orders necessary to evaluate and monitor the completeness of University of Perpetual Help Delta Medical Center, Inc.'s data breach notification and assess its breach management pursuant to NPC Circular 16-03 (Personal Data Breach Management).

SO ORDERED.

City of Pasay, Philippines.
08 February 2024.

SGD
JOHN HENRY D. NAGA
Privacy Commissioner

WE CONCUR:

SGD
LEANDRO ANGELO Y. AGUIRRE
Deputy Privacy Commissioner

SGD
NERISSA N. DE JESUS
Deputy Privacy Commissioner

Copy furnished:

PJM

Data Protection Officer

University of Perpetual Help Dalta Medical Center, Inc.

RMT

President

University of Perpetual Help Dalta Medical Center, Inc.

COMPLIANCE AND MONITORING DIVISION

ENFORCEMENT DIVISION

GENERAL RECORDS UNIT

National Privacy Commission